

Application e-commerce - Exigences métier

Table of Contents

1. Objectif et périmètre	1
2. Acteurs concernés	1
3. Besoins de l'Administrateur	2
4. Besoins du Vendeur	3
5. Besoins de l'Acheteur	4
6. Contraintes opérationnelles	5
7. Matrice de traçabilité	6
8. Exigences de sécurité	7
8.1. Authentification et gestion des accès	8
8.2. Mots de passe	8
8.3. Stockage des mots de passe	9
8.4. Sécurité des communications	10
8.5. Sécurité applicative	10
8.6. Journalisation et surveillance	11

1. Objectif et périmètre

Ce document recense les **besoins opérationnels** de l'application e-commerce, c'est-à-dire ce que les acteurs ont besoin de pouvoir faire dans leur contexte métier réel, indépendamment de tout système à construire.

Les besoins sont dérivés directement de l'Analyse du Besoin Opérationnel (OA — voir [01-operational-analysis/oa.adoc](#)). Ils constituent la référence à satisfaire ; la manière dont le système y répond est documentée aux niveaux SA, LA et PA de l'architecture ARCADIA.

Un besoin opérationnel exprime **la nécessité d'un acteur** (ce qu'il doit pouvoir accomplir dans son activité), non une fonction système.

2. Acteurs concernés

Acteur	Type	Rôle dans l'opération
Administrateur	Acteur principal interne	Gestionnaire des comptes utilisateurs et des transporteurs ; garant de la disponibilité de la plateforme

Acteur	Type	Rôle dans l'opération
Vendeur	Acteur principal interne	Exploitant de la boutique : catalogue, stocks, commandes, expéditions, facturation et service client
Acheteur	Acteur principal externe	Client final résidant dans la zone euro : navigation, achat, paiement, suivi et retour
Transporteur	Acteur externe	Prestataire logistique ; prend en charge les colis déposés par le vendeur et assure la livraison dans la zone euro
Prestataire de paiement	Système externe	Autorisation et confirmation des transactions bancaires ; traitement des remboursements
Service de messagerie	Système externe	Acheminement des emails vers les boîtes mail des acteurs (activation, notifications, confirmations)

3. Besoins de l'Administrateur

Identifiant	Besoin	Source OA
BES-ADM-001	L'administrateur a besoin de créer des comptes utilisateurs (acheteurs et vendeurs) sur la plateforme.	UC_A1, Acteurs opérationnels
BES-ADM-002	L'administrateur a besoin de suspendre un compte utilisateur pour en bloquer temporairement l'accès.	UC_A1, Activités administrateur
BES-ADM-003	L'administrateur a besoin de supprimer un compte utilisateur de la plateforme.	UC_A1, Activités administrateur
BES-ADM-004	L'administrateur a besoin de gérer les droits d'accès des utilisateurs à la plateforme.	UC_A1b, Acteurs opérationnels
BES-ADM-005	L'administrateur a besoin d'ajouter des transporteurs disponibles pour les expéditions vers la zone euro.	UC_A2a, Activités administrateur
BES-ADM-006	L'administrateur a besoin de modifier ou supprimer les transporteurs existants.	UC_A2b, Activités administrateur
BES-ADM-007	L'administrateur a besoin d'activer ou de désactiver le mode maintenance de la boutique, rendant toutes les pages inaccessibles aux utilisateurs non-administrateurs pendant la maintenance.	UC_A3, Activités administrateur

4. Besoins du Vendeur

Identifiant	Besoin	Source OA
BES-VND-001	Le vendeur a besoin de mettre à jour ses informations personnelles de compte (nom, adresse, mot de passe, coordonnées).	UC_V0, Activités vendeur
BES-VND-002	Le vendeur a besoin de créer, modifier et supprimer des fiches produits dans le catalogue (photos, descriptions, prix, catégories).	UC_V1, Activités vendeur
BES-VND-003	Le vendeur a besoin de suivre les niveaux de stock, d'anticiper les ruptures et d'effectuer les réapprovisionnements.	UC_V2, Activités vendeur
BES-VND-004	Le vendeur a besoin de prendre en charge les commandes reçues, de vérifier la disponibilité du stock et de préparer les colis.	UC_V3, Activités vendeur
BES-VND-005	Le vendeur a besoin de marquer une commande comme expédiée en saisissant le numéro de suivi obtenu sur le reçu du transporteur lors du dépôt physique du colis.	UC_V4, Activités vendeur, Diagramme d'activité
BES-VND-006	Le vendeur a besoin de confirmer manuellement dans la boutique la réception effective d'un virement bancaire afin de déclencher la prise en charge de la commande correspondante.	Activités vendeur, COp-02, Diagramme de séquence
BES-VND-007	Le vendeur a besoin de traiter les réclamations et litiges des acheteurs (répondre aux demandes de remboursement, gérer les retours produits).	UC_V5, Activités vendeur
BES-VND-008	Le vendeur a besoin d'accepter ou de refuser une demande d'annulation soumise par un acheteur après expédition, en choisissant entre deux modalités : avec condition de renvoi du colis ou sans condition de renvoi.	UC_V8, Activités vendeur, Diagramme d'activité
BES-VND-009	Le vendeur a besoin d'émettre un virement bancaire inverse vers l'acheteur et de confirmer son émission dans la boutique lorsqu'une commande réglée par virement est annulée.	Activités vendeur, Diagramme d'activité
BES-VND-010	Le vendeur a besoin de consulter des rapports de ventes (chiffre d'affaires, produits les plus vendus, statistiques commerciales).	UC_V6, Activités vendeur
BES-VND-011	Le vendeur a besoin de créer, modifier et supprimer des annonces défilantes affichées sur la page d'accueil de la boutique.	UC_V9, Activités vendeur

Identifiant	Besoin	Source OA
BES-VND-012	Le vendeur a besoin d'importer en masse de nouveaux produits dans son catalogue depuis un fichier CSV, afin de gagner du temps lors d'une initialisation ou d'un renouvellement important de l'offre.	UC_V1, Activités vendeur
BES-VND-013	Le vendeur a besoin d'exporter l'ensemble de son catalogue produits au format CSV afin de le consulter hors ligne, le partager ou le réimporter ultérieurement.	UC_V1, Activités vendeur
BES-VND-014	Le vendeur a besoin de mettre à jour les niveaux de stock de plusieurs produits simultanément depuis une vue liste, sans avoir à ouvrir chaque fiche produit individuellement.	UC_V2, Activités vendeur

5. Besoins de l'Acheteur

Identifiant	Besoin	Source OA
BES-ACH-001	L'acheteur a besoin de créer un compte sur la boutique en saisissant ses informations personnelles.	UC_B0, Activités acheteur
BES-ACH-002	L'acheteur a besoin d'activer son compte en consultant sa boîte mail et en cliquant sur le lien d'activation qui lui est adressé après inscription, avant de pouvoir utiliser la boutique.	UC_B0B, Activités acheteur, COp-04
BES-ACH-003	L'acheteur a besoin de s'authentifier pour accéder aux fonctionnalités d'achat (panier, commande, suivi, annulation).	UC_B_AUTH, Activités acheteur
BES-ACH-004	L'acheteur a besoin de mettre à jour ses informations personnelles (adresse de livraison, mot de passe, coordonnées).	UC_B_ACC, Activités acheteur
BES-ACH-005	L'acheteur a besoin de parcourir, rechercher et filtrer les produits disponibles dans le catalogue.	UC_B1, Activités acheteur
BES-ACH-006	L'acheteur a besoin de gérer son panier : ajouter des produits, modifier les quantités, retirer des articles.	UC_B2, Activités acheteur
BES-ACH-007	L'acheteur a besoin que son panier soit automatiquement sauvegardé lorsqu'il quitte la boutique et restauré tel quel à la reconnexion.	UC_B2B, Activités acheteur, COp-03

Identifiant	Besoin	Source OA
BES-ACH-008	L'acheteur a besoin de passer une commande en saisissant une adresse de livraison dans un pays de la zone euro et en choisissant le mode de livraison disponible.	UC_B3, UC_B4B, Activités acheteur
BES-ACH-009	L'acheteur a besoin de régler ses commandes par carte bancaire (autorisation immédiate) ou par virement bancaire (la commande reste en attente de confirmation manuelle du vendeur jusqu'à réception effective des fonds).	UC_B4, Activités acheteur, COp-02
BES-ACH-010	L'acheteur a besoin de suivre l'état d'expédition de sa commande et de consulter le numéro de suivi de son colis.	UC_B5, Activités acheteur
BES-ACH-011	L'acheteur a besoin d'annuler en autonomie depuis son espace compte une commande dont le colis n'a pas encore été remis au transporteur, avec déclenchement automatique du remboursement sans intervention du vendeur.	UC_B6, Activités acheteur, Diagramme d'activité
BES-ACH-012	L'acheteur a besoin de contacter le vendeur pour demander l'annulation ou le retour d'une commande déjà expédiée, et d'être informé de l'acceptation ou du refus de sa demande.	UC_B7, Activités acheteur, Diagramme de séquence
BES-ACH-013	L'acheteur a besoin de gérer un carnet d'adresses de livraison : ajouter plusieurs adresses, les modifier, les supprimer et en désigner une par défaut, afin de sélectionner rapidement une adresse existante lors du passage d'une commande.	UC_B_ACC, Activités acheteur

6. Contraintes opérationnelles

Les contraintes suivantes s'imposent indépendamment des acteurs et de toute décision d'architecture. Elles proviennent du contexte d'usage réel.

Identifiant	Contrainte	Description
COp-01	Interface responsive (PC / smartphone)	Les acteurs interagissent avec la boutique depuis des environnements variés. L'acheteur utilise principalement un smartphone ; le vendeur et l'administrateur opèrent depuis un ordinateur. L'interface doit s'adapter à toutes ces résolutions sans dégradation de l'expérience utilisateur.

Identifiant	Contrainte	Description
COp-02	Modes de paiement acceptés	L'acheteur doit pouvoir régler par carte bancaire (traitement automatique via le prestataire externe) ou par virement bancaire (la commande reste en attente de confirmation manuelle du vendeur jusqu'à réception effective des fonds).
COp-03	Persistance du panier entre sessions	Le panier d'un acheteur authentifié est automatiquement sauvegardé sur son compte et restauré tel quel à la reconnexion.
COp-04	Activation de compte par email	Le compte d'un acheteur n'est accessible qu'après activation via un lien reçu par email suite à l'inscription.

7. Matrice de traçabilité

Le tableau ci-dessous relie chaque besoin opérationnel aux activités et cas d'utilisation de l'OA dont il est issu.

Besoin	Acteur	Origine OA (activité / cas d'utilisation)
BES-ADM-001	Administrateur	UC_A1 — Créer / suspendre / supprimer un compte
BES-ADM-002	Administrateur	UC_A1 — Activité « Gérer les comptes utilisateurs »
BES-ADM-003	Administrateur	UC_A1 — Activité « Gérer les comptes utilisateurs »
BES-ADM-004	Administrateur	UC_A1b — Gérer les droits d'accès
BES-ADM-005	Administrateur	UC_A2a — Ajouter un transporteur
BES-ADM-006	Administrateur	UC_A2b — Modifier / supprimer un transporteur
BES-ADM-007	Administrateur	UC_A3 — Basculer en mode maintenance
BES-VND-001	Vendeur	UC_V0 — Mettre à jour son compte
BES-VND-002	Vendeur	UC_V1 — Gérer le catalogue produits
BES-VND-003	Vendeur	UC_V2 — Gérer les stocks
BES-VND-004	Vendeur	UC_V3 — Traiter les commandes reçues
BES-VND-005	Vendeur	UC_V4 — Expédier vers la zone euro
BES-VND-006	Vendeur	COp-02 — Confirmer réception virement bancaire
BES-VND-007	Vendeur	UC_V5 — Traiter les litiges et réclamations

Besoin	Acteur	Origine OA (activité / cas d'utilisation)
BES-VND-008	Vendeur	UC_V8 — Traiter un retour après expédition
BES-VND-009	Vendeur	Activité « Émettre un virement inverse de remboursement »
BES-VND-010	Vendeur	UC_V6 — Consulter les rapports de ventes
BES-VND-011	Vendeur	UC_V9 — Gérer les annonces défilantes
BES-VND-012	Vendeur	UC_V1 — Import CSV catalogue (nouveaux produits)
BES-VND-013	Vendeur	UC_V1 — Export CSV catalogue
BES-VND-014	Vendeur	UC_V2 — Mise à jour en masse des stocks
BES-ACH-001	Acheteur	UC_B0 — S'inscrire
BES-ACH-002	Acheteur	UC_B0B — Activer son compte via email ; COp-04
BES-ACH-003	Acheteur	UC_B_AUTH — S'authentifier
BES-ACH-004	Acheteur	UC_B_ACC — Mettre à jour son compte
BES-ACH-005	Acheteur	UC_B1 — Parcourir le catalogue
BES-ACH-006	Acheteur	UC_B2 — Gérer le panier
BES-ACH-007	Acheteur	UC_B2B — Sauvegarder / restaurer le panier ; COp-03
BES-ACH-008	Acheteur	UC_B3, UC_B4B — Passer une commande
BES-ACH-009	Acheteur	UC_B4 — Effectuer un paiement ; COp-02
BES-ACH-010	Acheteur	UC_B5 — Suivre la livraison
BES-ACH-011	Acheteur	UC_B6 — Annuler une commande (avant expédition)
BES-ACH-012	Acheteur	UC_B7 — Demander une annulation après expédition
BES-ACH-013	Acheteur	UC_B_ACC — Gérer le carnet d'adresses de livraison

8. Exigences de sécurité

Les exigences suivantes sont issues des guides et recommandations publiés par l'ANSSI (Agence nationale de la sécurité des systèmes d'information). Elles s'appliquent à la plateforme indépendamment des besoins métier.

Sources principales : [ANSSI-BP-076](#) et [ANSSI-PG-078 v2.0](#) — Recommandations relatives à l'authentification multifacteur et aux mots de passe.

8.1. Authentification et gestion des accès

Référence : ANSSI-BP-076 / ANSSI-PG-078 v2.0

Identifiant	Exigence	Réf. ANSSI	Acteurs
SEC-AUTH-001	Les mots de passe des comptes doivent comporter au minimum 12 caractères et combiner majuscules, minuscules, chiffres et caractères spéciaux.	PG-078 R21, R23	Tous
SEC-AUTH-002	Les mots de passe doivent être stockés sous forme hachée avec un algorithme résistant (BCrypt, Argon2id ou scrypt) ; le stockage en clair ou en MD5/SHA-1 est interdit.	BP-076 §3.3 / PG-078 R28, R29	—
SEC-AUTH-003	Les tentatives d'authentification échouées répétées doivent déclencher un mécanisme de protection (temporisation progressive, verrouillage temporaire ou CAPTCHA) afin de prévenir les attaques par force brute.	BP-076 §3.2 / PG-078 R10	Tous
SEC-AUTH-004	Les sessions authentifiées doivent expirer après une période d'inactivité de 30 minutes maximum. La déconnexion explicite doit invalider immédiatement le jeton de session côté serveur. Les cookies de session doivent avoir une durée de vie limitée.	BP-076 §4.1 / PG-078 R12	Tous
SEC-AUTH-005	Les droits d'accès doivent respecter le principe du moindre privilège : chaque rôle (administrateur, vendeur, acheteur) ne doit accéder qu'aux ressources strictement nécessaires à ses activités.	BP-076 §2.1	Tous
SEC-AUTH-006	En cas d'échec d'authentification, le système ne doit pas indiquer quel facteur (identifiant ou mot de passe) a conduit à l'échec. Un message générique uniforme doit être retourné.	PG-078 R14	Tous
SEC-AUTH-007	L'authentification multifacteur (MFA) doit être proposée pour les comptes Vendeur et Administrateur.	PG-078 R1	Vendeur, Administrateur
SEC-AUTH-008	Le SMS ne doit pas être utilisé comme canal de réception d'un facteur d'authentification (vulnérabilité SIM-swap et interception réseau).	PG-078 R8	Tous

8.2. Mots de passe

Référence : ANSSI-PG-078 v2.0

Identifiant	Exigence	Réf. ANSSI	Acteurs
SEC-PWD-001	Aucune longueur maximale ne doit être imposée sur les mots de passe, afin de permettre l'utilisation de phrases de passe longues.	PG-078 R22	Tous
SEC-PWD-002	La robustesse du mot de passe doit être contrôlée automatiquement à la création et au renouvellement. Les mots de passe figurant dans des listes de mots de passe compromis (ex. HaveIBeenPwned) doivent être rejetés.	PG-078 R27	Tous
SEC-PWD-003	Aucune expiration automatique de mot de passe ne doit être imposée aux comptes Acheteur (sensibilité non élevée).	PG-078 R24	Acheteur
SEC-PWD-004	Un délai d'expiration doit être imposé sur les mots de passe des comptes Administrateur (entre 1 et 3 ans).	PG-078 R25	Administrateur
SEC-PWD-005	En cas de compromission suspectée ou avérée, tous les mots de passe concernés doivent être révoqués dans la journée. Les comptes dont le mot de passe n'a pas été renouvelé doivent être désactivés.	PG-078 R26	Tous
SEC-PWD-006	Une méthode de recouvrement d'accès doit être proposée sous forme de lien de réinitialisation temporaire et à usage unique. Le mot de passe ne doit jamais être transmis en clair par quelque canal que ce soit.	PG-078 R30	Tous

8.3. Stockage des mots de passe

Référence : ANSSI-PG-078 v2.0

Identifiant	Exigence	Réf. ANSSI	Acteurs
SEC-STORE-001	Les mots de passe ne doivent jamais être stockés en clair. Seules leurs empreintes cryptographiques doivent être conservées.	PG-078 R28, R29	—
SEC-STORE-002	Un sel aléatoire d'au moins 128 bits, unique par compte, doit être utilisé lors du calcul de l'empreinte du mot de passe.	PG-078 R28	—
SEC-STORE-003	Les empreintes doivent être calculées avec une fonction de dérivation à coût mémoire élevé : Argon2 ou scrypt en priorité, BCrypt en alternative acceptable.	PG-078 R29, R29-	—

Identifiant	Exigence	Réf. ANSSI	Acteurs
SEC-STORE-004	L'accès à la base de données contenant les empreintes de mots de passe doit être protégé en confidentialité et en intégrité (accès réseau restreint, chiffrement des colonnes sensibles).	PG-078 R13	—

8.4. Sécurité des communications

Référence : [ANSSI-BP-113 — Recommandations de sécurité relatives à TLS](#)

Identifiant	Exigence	Référence ANSSI
SEC-TLS-001	Toutes les communications entre les clients (navigateurs, API) et la plateforme doivent être chiffrées via TLS 1.2 au minimum ; TLS 1.3 est recommandé. Les versions SSLv3, TLS 1.0 et TLS 1.1 sont interdites.	ANSSI-BP-113 §3.1
SEC-TLS-002	Les certificats TLS doivent être émis par une autorité de certification reconnue, valides et renouvelés avant expiration.	ANSSI-BP-113 §4.1
SEC-TLS-003	Le cookie de session doit porter les attributs Secure , HttpOnly et SameSite=Strict afin d'empêcher son interception ou sa lecture par des scripts.	ANSSI-BP-113 §5.2

8.5. Sécurité applicative

Référence : [ANSSI — Recommandations pour la sécurisation des sites web](#)

Identifiant	Exigence	Référence ANSSI
SEC-APP-001	Toutes les données saisies par les utilisateurs doivent être validées et assainies côté serveur avant tout traitement ou persistance, afin de prévenir les injections (SQL, commandes, LDAP) et les attaques XSS.	ANSSI Web §3.1
SEC-APP-002	Les formulaires et requêtes d'état (commande, paiement, modification de compte) doivent être protégés contre les attaques CSRF par jeton anti-forgery ou vérification de l'en-tête Origin .	ANSSI Web §3.3
SEC-APP-003	Les messages d'erreur retournés aux utilisateurs ne doivent pas exposer d'informations techniques internes (traces de pile, noms de tables, chemins de fichiers).	ANSSI Web §4.2
SEC-APP-004	Les composants tiers (bibliothèques, frameworks, dépendances) doivent être maintenus à jour et exempts de vulnérabilités critiques connues (CVE de score CVSS ≥ 7.0).	ANSSI Web §5.1

Identifiant	Exigence	Référence ANSSI
SEC-APP-005	Une politique de sécurité du contenu (Content Security Policy) doit être définie et appliquée via l'en-tête HTTP Content-Security-Policy pour restreindre les sources de scripts et ressources chargées par le navigateur.	ANSSI Web §3.4

8.6. Journalisation et surveillance

Référence : ANSSI — Recommandations de sécurité pour l'administration des systèmes d'information / ANSSI-PG-078 v2.0

Identifiant	Exigence	Réf. ANSSI	Acteurs
SEC-LOG-001	Les événements liés à l'authentification doivent être journalisés avec horodatage, identifiant utilisateur et adresse IP : création de compte, tentatives réussies et échouées, demandes de renouvellement de mot de passe, révocations, actions d'administration, transactions de paiement.	ANSSI Admin §4.1 / PG-078 R9	Tous
SEC-LOG-002	Les journaux d'authentification et de sécurité doivent permettre la détection de comportements anormaux (tentatives répétées, connexions inhabituelles) et faciliter les investigations en cas d'incident.	ANSSI Admin §4.2 / PG-078	Tous
SEC-LOG-003	Les journaux de sécurité doivent être conservés pendant une durée minimale de 12 mois et protégés contre toute modification ou suppression non autorisée.	ANSSI Admin §4.2	—
SEC-LOG-004	Les accès aux journaux doivent être restreints aux seuls administrateurs de la plateforme.	ANSSI Admin §4.3	Administrateur